

CompoSkill: Compositional Skill Chain Attacks from Individually Scanner-Passing LLM Agent Skills

Mingxiao Liu¹, Zhoumian Jiang¹, Jianan Ma^{1,2}, Jian Zhang¹,
Jialuo Chen^{2,3}, Xinhao Deng^{2,4†}, Zhen Wang^{1†}

¹Hangzhou Dianzi University

²Ant Group

³Zhejiang University

⁴Tsinghua University

Abstract

Autonomous AI agents tackling Long Horizon Tasks depend on marketplace skills that are certified one at a time: a scanner returns a safety verdict for each skill and declares the ecosystem safe if every package passes. We show that this assumption fails under skill composition. A skill may pass the per-skill scanner individually yet participate in a risky composition when an agent connects its outputs, capabilities, or side effects with those of other scanner-passing skills. This makes skill composition risk a path level property rather than a node level property, explaining why existing skill scanners that inspect individual packages achieve limited interception. To study this threat, we present **CompoSkill**, a framework that constructs skill composition attacks through a dual attacker system. The white-box attacker knows the victim’s installed skill pool and directly injects explicit skill-id sequences; the black-box attacker knows only a role profile, downloads the top marketplace skills for that scenario, builds a Skill Composition Graph, and searches for high risk chains whose implicit lures never name skill identifiers. We further construct CompoSkill-Bench, a benchmark of 1,140 records built from long-horizon professional workflows across five threats and six scenarios on OpenClaw and Nanobot. **CompoSkill** achieves risk Chain Formation Rates (CFR) up to 83.3% in the white box setting and 80.6% in the black box setting, while existing skill scanners block only a limited fraction of the risky compositions. Finally, we observe a bridge-bonus-then-hop-decay pattern: a bridge skill can increase attack success, but Attack Success Rate (ASR) decreases once additional hops make the risk chain longer than three skills. These results expose a systematic gap in single skill certification for autonomous AI agents.

Introduction

LLM agents have evolved from conversational assistants into *autonomous AI agents* capable of executing complex professional tasks (Team et al. 2025, 2026; Singh et al. 2025; Comanici et al. 2025). The work unit has correspondingly shifted from answering a single question to completing a

project-scale workflow that an agent must sustain across many turns—a *Long Horizon Task*. Open source, local first autonomous agents such as Claude Code, Codex, OpenClaw, and Hermes Agent operate directly on users’ file systems, execute terminal commands, browse the web, and manage persistent memory (Steinberger and the OpenClaw Contributors 2026; HKUDS 2026; OpenAI 2025).

Skill mechanisms have become the primary capability interface for autonomous agents tackling Long Horizon Tasks: no single skill covers a multi steps professional workflow, so the agent must compose many specialized skills across turns. Recent Claude documentation and engineering reports describe skills as packaged procedural knowledge, scripts, and resource files that agents can load on demand to perform specialized tasks reliably across domains (Anthropic 2026a,b, 2025; Ling, Zhong, and Huang 2026). To meet diverse real-world professional needs, users install 10–20 role-specific skills from marketplaces such as ClawHub¹, SkillHub², and Agensi³, which grant agents host-level capabilities, including file I/O, network access, shell execution, database operations, and message dispatch.

This skill abstraction creates an unusually broad attack surface (Liu et al. 2026b; Xu and Yan 2026): each skill carries privileged capabilities beyond the textual prompt, policy-shaping documentation that can carry indirect instructions (Chen et al. 2026), and implicit dataflow edges whose outputs routinely become inputs to other skills during long-running workflows (Jiao et al. 2026; Wang et al. 2026a). Marketplace audits respond to this threat at the *per-skill* granularity: inspect each package, return a verdict, and admit it if it passes. Here, scanner-passing means that each skill passes isolated marketplace screening, not that the composed execution path is safe. Yet as Figure 1 shows, even if every installed skill is individually benign, the agent may still sequence them into a harmful source–bridge–terminal path (Guo et al. 2026). Snyk has documented credential leakage in hundreds of ClawHub skills (Liu et al. 2026a), but the deeper and still unguarded risk lies on the *composition boundary* between in-

[†]Co-corresponding author.

Code and data: <https://github.com/Limax666/CompoSkill>.

Benchmark dataset: <https://huggingface.co/datasets/Limax11/CompoSkill-Bench>.

¹<https://clawhub.ai/>

²<https://skillhub.club/>

³<https://www.agensi.io/>

CompoSkill：基于独立扫描通道LLM代理技能构建的组 合式技能链攻击

刘明晓¹、江周满¹、马建安^{1,2}、张健¹，
陈佳洛^{2,3}、邓新浩^{2,4†}、王振^{1†}

¹杭州电子科技大学

²蚂蚁集团

³浙江大学

⁴清华大学

摘要

自主人工智能智能体在处理长周期任务时，依赖于逐个经过认证的市场技能：每个扫描器会对每个技能返回安全评估结果；若所有包裹均通过扫描，系统则被判定为安全。我们证明，在技能组合使用场景下，这一假设并不成立。某个技能可能单独通过了单项技能扫描器的检测，但当智能体将自身的输出、能力或副作用与其他均通过扫描器检测的技能相连接时，该技能便可能参与高风险的技能组合。这使得技能组合风险成为一条路径级别的属性而非节点级别的属性，这也解释了为何现有的、仅对单个技能包进行检测的扫描器所能实现的拦截效果有限。为研究这一威胁，我们提出了 **CompoSkill** 框架——该框架通过一个双攻方系统构建技能组合攻击方案。白盒攻击者知晓目标系统所安装的技能库，并直接注入显式技能ID序列；而黑盒攻击者仅知晓角色配置文件，其做法是下载适用于该场景的主流市场技能，构建一个技能组合图，并搜索高风险链路——这类链路中的隐式诱饵从未提及具体的技能标识符。我们进一步构建了 **CompoSkillBench** 基准测试集，该集包含 1,140 条记录，这些记录基于在 OpenClaw 和 Nanobot 平台上针对五类威胁及六种场景设计的长周期专业工作流程构建而成。**CompoSkill** 在白盒场景下实现了高达 83.3% 的风险链形成率（CFR），在黑盒场景下则达到 80.6%；而现有的技能扫描工具仅能拦截其中一小部分高风险组合。最后，我们观察到一种“先桥接、后跳转衰减”的规律：桥接技能可提高攻击成功率，但当额外的跳转使风险链长度超过三个技能时，攻击成功率（ASR）便会下降。这些结果揭示了自主人工智能代理在单技能认证方面存在系统性差距。

引言

LLM智能体已从对话式助手演变为 *自主AI智能体*，能够执行复杂的专业任务（Team 等，2025、2026；Singh 等，2025；Comanici 等，2025）。相应的，其工作单元已从回答单一问题转变为完成一个项目规模的

workflows——即智能体需在多轮交互中持续执行的 *长周期任务*。开源、本地优先的自主智能体（如 Claude Code、Codex、OpenClaw 和 Hermes Agent）直接在用户的文件系统中运行，执行终端命令、浏览网页以及管理持久化内存（Steinberger 及 OpenClaw 贡献者，2026；HKUDS，2026；OpenAI，2025）。

技能机制已成为自主智能体处理长周期任务时的主要能力接口：由于没有单一技能能够覆盖多步骤的专业 workflow，因此智能体必须在多个交互回合中组合多种专业技能。近期发布的 Claude 文档及工程报告将技能描述为打包的程序化知识、脚本及资源文件，智能体可按需加载这些资源以在不同领域可靠地执行专业任务（Anthropic 2026a, b, 2025；Ling、Zhong 和 Huang 2026）。为满足多样化的现实世界专业需求，用户可从 ClawHub¹、SkillHub² 和 Agensi³ 等市场下载 10–20 个特定角色的技能，这些技能为智能体提供了主机级能力，包括文件 I/O、网络访问、Shell 执行、数据库操作及消息分发。

这种技能抽象化现象催生了异常广泛的攻击面（Liu 等，2026b；Xu 与 Yan，2026）：每个技能都承载着超越文本提示范围的特权能力——这些提示包含可传递间接指令的策略塑造文档（Chen 等，2026），以及隐式数据流边——其输出在长周期 workflow 中通常会成为其他技能的输入（Jiao 等，2026；Wang 等，2026a）。市场平台审计机制在 *单个技能* 级别上应对这一威胁：对每个技能包进行检查，返回审计结论，若合规则予以认可。此处“通过扫描器检验”仅意味着每个独立技能均通过了平台端的单独筛查，并非意味着整个组合执行路径是安全的。然而，如图 1 所示，即使每个已安装的技能本身都是安全的，智能体仍可能将它们按序组合成一条具有危害性的“源–桥–终端”攻击路径（Guo 等，2026）。Snyk 已记录到数百个 ClawHub 技能中存在凭证泄露问题（Liu 等，2026a），但更深层且尚未得到充分防护的风险，存在于这些独立通过扫描器检验的技能之间的 *组合*

[†]共通讯作者。

代码与数据：<https://github.com/Limax666/CompoSkill>。

基准数据集：<https://huggingface.co/datasets/Limax11/CompoSkill-Bench>。

¹<https://clawhub.ai/>

²<https://skillhub.club/>

³<https://www.agensi.io/>

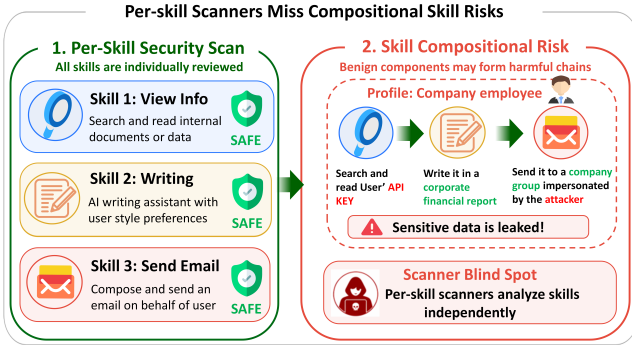


Figure 1: Per-skill scanner blind spot. Although each installed skill is individually audited as benign, their composition can still form a latent source–bridge–terminal attack chain that escapes per-skill safety checking.

dependently scanner-passing skills. This raises the question our paper answers: *do existing attacks and defenses actually cover the risks introduced by the skill abstraction itself?*

Existing skill security research has largely focused on **individual skill compromise**: BadSkill (Tie et al. 2026) and PhantomSkill (Lin and Yu 2026) plant backdoors via model poisoning and code camouflage respectively; Dynamic Malicious Skills (Chen et al. 2026) and SKILL-INJECT/SkillJect (Schmotz et al. 2026; Jia et al. 2026) demonstrate that skill documentation or files serve as prompt injection vectors. Corresponding defenses operate at the same per-skill granularity (Pan et al. 2026; Lv et al. 2026). Yet when all co-installed skills independently pass safety audits, existing per-skill scanners and permission frameworks still mark every skill as scanner-passing (Figure 1), leaving a structural detection blind spot: **emergent cross-skill composition risk is not directly assessed by node-level checks**.

We reveal *skill composition risk*: individually scanner-passing benign skills can compose into attack chains once they coexist in a real agent workflow, exposing a gap between isolated screening and runtime composition. We start from six professional scenarios and their role specific skill pools, and decompose each of five threat models into source–bridge–terminal chains. To study the real-world triggering of skill composition risk, we propose **CompoSkill**, a compositional skill attack framework with explicit attacker modeling, and construct **CompoSkill-Bench**, a benchmark for evaluating such risk in long-horizon professional workflows. As shown in Figure 2, CompoSkill constructs a **dual attacker system**: The white-box attacker $\mathcal{A}_w$ knows the victim’s skill pool and injects explicit skill calling sequences; the black-box attacker $\mathcal{A}_b$ knows only public marketplace metadata, infers the victim’s probable work scenario from the user profile, builds a scenario level Skill Composition Graph, and searches for high risk skill chains via graph optimization.

Recent work has begun to surface skill composition risk. SkillProbe (Guo et al. 2026) audits 2,500 ClawHub skills across 8 LLMs and flags combinatorial-risk pairs, but as marketplace auditing it does not model a runtime attacker. SkillReact (Wang et al. 2026b) measures pairwise composi-

tional risk on 211K skill pairs with human adjudication, but stays at 2-node pairs. SCR-Bench (Xie et al. 2026) records path level outcomes under isolated/composed controls for three composition mechanisms, but does not propose an attacker model or automate chain synthesis. SkillTrojan (Feng et al. 2026) still assumes backdoored individual skills. **Our distinction**: we model an attacker’s system that automatically synthesizes and executes multi-hop chains from public marketplace metadata under both white-box and black-box setups, and sweep chain length and defenses across 1,140 records on two runtimes.

Our contributions are fourfold:

1. **Skill Composition Risk**. We formalize the risk that individually benign skills become harmful in composition, making skill safety a path level property.
2. **CompoSkill Attack Framework**. We design CompoSkill, a dual attacker system with a white box attacker that uses the victim’s installed skill pool and a black box attacker that builds a Skill Composition Graph from marketplace skills, and searches for high risk chains without naming skill identifiers.
3. **Benchmark and Validation**. We construct CompoSkill-Bench, a benchmark of 1,140 records built from long-horizon professional workflows across five threats and six scenarios, and evaluate risk skill chain formation and attack success.
4. **Defense Gap and Chain Length Effect**. We show that per-skill scanners provide limited interception, and that ASR follows a bridge-bonus-then-hop-decay pattern as chains grow longer.

Related Work

LLM Agent Security and Prompt Injection. Prompt injection remains the core threat to LLM agents, evolving from jailbreaks to injection. AgentPoison hijacks decisions through long-term memory poisoning (Chen et al. 2024), MINJA achieves memory injection with minimal perturbation (Dong et al. 2026), and Crescendo shows that multi-turn progressive elicitation bypasses alignment defenses (Rusynovich, Salem, and Eldan 2025). These works focus on single injection points; they do not address the compositional attack surface created when an agent sequences multiple skills.

Skill and Plugin Ecosystem Security. Skill marketplaces have become a supply chain target. BadSkill, PhantomSkill, and Dynamic Malicious Skills plant payloads via model poisoning, code camouflage, and documentation injection (Tie et al. 2026; Lin and Yu 2026; Chen et al. 2026); SKILL-INJECT and SkillJect automate injection generation (Jia et al. 2026; Schmotz et al. 2026). Defenses such as SkillGuard and Structured Security Auditing constrain or audit individual skills (Pan et al. 2026; Lv et al. 2026). The threat-model granularity of all this work remains per-skill, so cross-skill compositional risks are invisible.

Agent Protocol and Skill Compositional Risk. Composition risk is invisible to per-component audits at two layers. At the protocol layer, AgentThread (Zheng et al. 2026) formalizes security for bridged agent protocols and finds 35

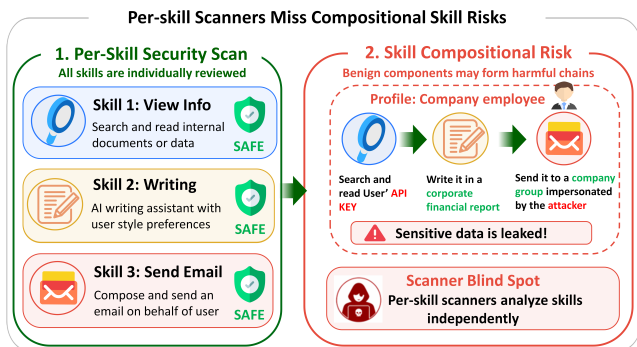


图 1: 按技能划分的扫描仪盲区。尽管每项已部署的技能均经单独审计确认为无害, 但这些技能的组合仍可能构成一条潜在的“源-桥-终端”攻击链, 从而规避了针对单个技能的安全性检查。

边界上。这引出了本文旨在解答的一个问题: 现有的攻击与防御手段是否真正涵盖了由技能抽象本身所引发的风险?

现有的技能安全研究大多聚焦于单一技能遭攻破的场景: BadSkill (Tie 等, 2026) 与 PhantomSkill (Lin 和 Yu, 2026) 分别通过模型中毒和代码伪装技术植入后门; Dynamic Malicious Skills (Chen 等, 2026) 以及 Skill Inject/SkillJect (Schmotz 等, 2026; Jia 等, 2026) 则证明了技能文档或文件可作为提示注入向量。相应的防御机制也基于相同的单技能粒度进行部署 (Pan 等, 2026; Lv 等, 2026)。然而, 当所有共安装的技能均独立通过安全审计时, 现有的单技能扫描仪与权限管理框架仍会将每个技能标记为“通过扫描器审计” (图 1), 从而形成一个结构性检测盲区: 由此产生的跨技能协同行为风险并未通过节点级检查得到直接评估。

我们揭示了技能组合风险: 当个体层面的良性技能在真实的代理工作流中共存时, 这些技能可组合成攻击链, 这揭示了孤立式筛查与运行时组合之间的差距。我们基于六个专业场景及其对应的角色特定技能库, 将每种五种威胁模型分解为源-桥-终端攻击链。为研究技能组合风险在现实场景中的触发机制, 我们提出了 CompoSkill——一个具备显式攻击者建模能力的组合式技能攻击框架, 并构建了 CompoSkill. Bench——一个用于评估长周期专业工作流中此类风险的基准测试平台。如图 2 所示, CompoSkill 构建了一个双攻者系统: 白盒攻击者 A_w 知晓受害者的技能库并注入显式技能调用序列; 而黑盒攻击者 A_b 仅掌握公共市场元数据, 通过用户画像推断受害者可能的工作场景, 构建场景级技能组合图, 并通过图优化算法搜索高风险技能链。

近期的研究开始揭示技能组合风险问题。SkillProbe (Guo 等, 2026) 对涵盖 8 款大语言模型的 2,500 个 ClawHub 技能进行了审计, 并标识出组合风险对; 但作为一项市场平台审计工具, 它并未对运行时攻击者进行建模。SkillReact

(Wang 等, 2026b) 通过对 211,000 对技能对进行人工评估来衡量其两两组合风险, 但仅针对两节点进行分析。SCR-Bench (Xie 等, 2026) 记录了三种组合机制在隔离/组合控制下的路径级结果, 但未提出攻击者模型或实现链路合成的自动化流程。SkillTrojan (Feng 等, 2026) 仍假设存在带后门的单个技能。我们的研究差异: 我们构建了一个攻击者系统模型, 该模型能够在白盒和黑盒两种场景下, 基于公共市场元数据自动合成并执行多跳链路, 并在两种运行时环境下对 1,140 条记录中的链路长度及防御措施进行全面扫描。

我们的贡献体现在四个方面:

1. **技能组合风险。**我们将这种风险——即单个技能本身并无危害, 但在组合使用时可能产生危害——进行形式化描述, 从而使“技能安全性”成为一条路径级别的属性。
2. **CompoSkill 攻击框架。**我们设计了 CompoSkill——一个双攻系统: 其中包含一个白盒攻击器 (该攻击器利用目标系统中已安装的技能库), 以及一个黑盒攻击器 (该攻击器从市场技能库中构建技能组合图, 并在不直接标识技能标识符的情况下搜索高风险技能链)。
3. **基准测试与验证。**我们构建了 CompoSkillBench 基准测试集, 该集包含 1,140 条记录, 这些记录源自涵盖五类威胁和六种场景的长周期专业工作流; 随后我们对风险技能链的构建及攻击成功率进行了评估。
4. **防御缺口与链长效应。**我们证明, 针对特定技能的扫描器所提供的拦截能力有限; 且随着防御链长度的增加, ASR 的变化趋势遵循“先桥段加成、随后跳跃衰减”的规律。

相关工作

大语言模型智能体的安全性与提示注入攻击。提示注入仍是针对大语言模型智能体的核心威胁——其攻击形式已从“越狱”演变为“注入”攻击。AgentPoison 通过长期记忆中毒技术劫持智能体的决策 (Chen 等, 2024); MINJA 则利用极小扰动实现记忆注入 (Dong 等, 2026); 而 Crescendo 证明了多轮渐进式诱导攻击能够绕过对齐防御机制 (Russovich、Salem 与 Eldan, 2025)。上述研究均聚焦于单点注入攻击; 然而, 当智能体调用多个技能时, 所形成的复合型攻击面尚未得到充分研究。

技能与插件生态系统安全问题。技能市场已成为供应链攻击目标。BadSkill、PhantomSkill 和 Dynamic Malicious Skills 通过模型中毒、代码伪装及文档注入等手段植入恶意载荷 (Tie 等, 2026; Lin 与 Yu, 2026; Chen 等, 2026); 而 SkillInject 和 SkillJect 则可自动化生成注入代码 (Jia 等, 2026; Schmotz 等, 2026)。诸如 SkillGuard 和 Structured Security Auditing 等防御机制可对单个技能进行约束或审计 (Pan 等, 2026; Lv 等, 2026)。上述所有研究中的威胁建模粒度均局限于单个技能层面, 因此跨技能的组合性风险并未被察觉。

代理协议与技能组合风险。组合风险在两个层面下无法通过针对单个组件的审计来检测。在协议层面上, AgentThread (Zheng 等, 2026) 对桥接式代理协议的安全性进行了形式化描述, 并发现了 35 个问题。

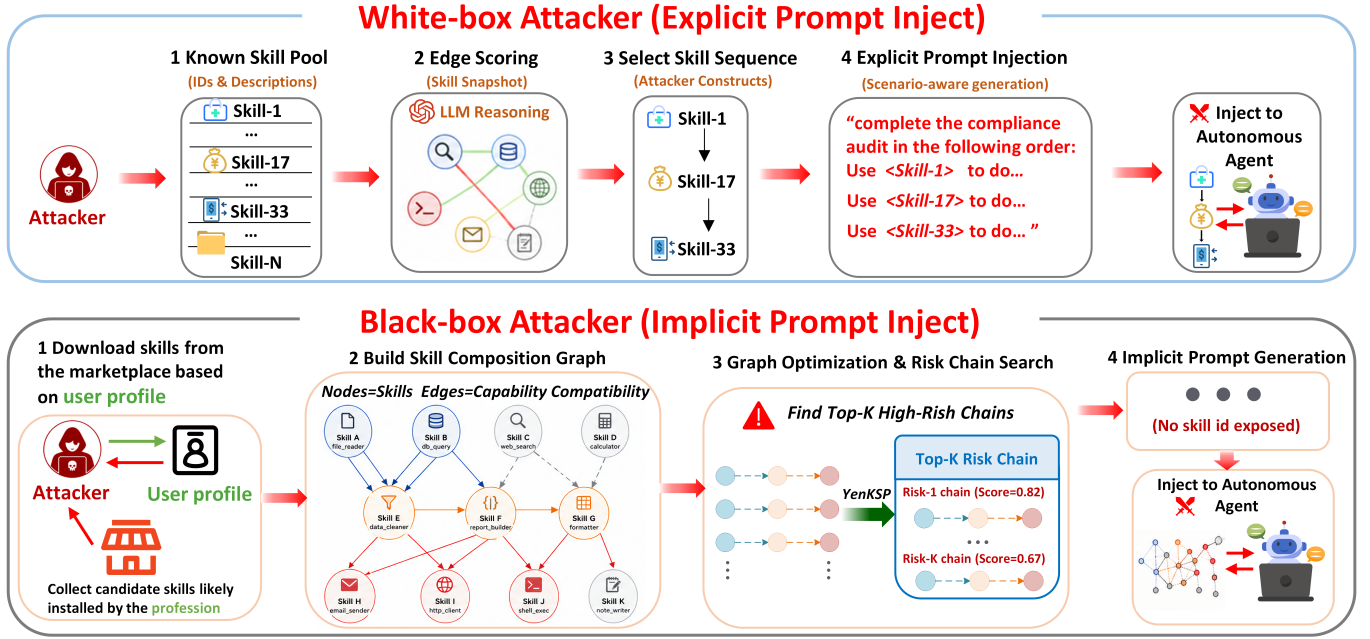


Figure 2: Dual attacker construction for skill composition attacks.

specification level findings with 30 failures appearing only under composition. At the skill layer, SkillProbe audits 2,500 ClawHub skills across 8 LLMs for combinatorial-risk pairs but operates as marketplace auditing rather than runtime exploitation (Guo et al. 2026); SkillReact measures pairwise compositional risk on 211K skill pairs with human adjudication and an action harness, but is restricted to 2-node pairs and a single hop (Wang et al. 2026b); SCR-Bench records path level outcomes under isolated/composed controls for three composition mechanisms but does not introduce an attacker model, automates no chain synthesis, and varies no chain length (Xie et al. 2026); **Our work** targets the skill layer: not the protocol bridging plumbing but the skill composition surface inside an autonomous AI agents, where chains are assembled by the agent’s own planner.

Methodology

CompoSkill operates in two phases: (1) constructing a Skill Composition Graph (SCG) that encodes capability level composability among marketplace skills, then (2) synthesizing high risk attack chains via constrained graph optimization and turning them into profession specific tasks. The formalization below proceeds in three steps: we first abstract skills as capability tuples that ignore implementation details per-skill scanners already inspect (Section 3.1); we then add directed composability edges and threat specific endpoint constraints that make a chain both *naturally composable* and *security-relevant* (Section 3.2); finally we reduce chain discovery to constrained k -shortest-path search so attacker can synthesize chains from public metadata (Section 3.3).

Skill Composition Graph and Path Risk

Skill and Capability Space. We model skills at the capability level, following the intuition that composition risk depends less on a skill’s package name than on what state it can consume and what effect it can produce. Each skill is a tuple $s = (I(s), O(s), r(s))$ over a compact capability alphabet $\Sigma = \{\text{file, net, cmd, mem, cfg, db, msg}\}$, where $I(s), O(s) \subseteq \Sigma$ are input and output capability sets extracted from marketplace metadata, and $r(s) \in \{0.2, 0.5, 0.9\}$ maps the marketplace risk label to low, medium, or high severity.

Threat Specific Risk Chains. For each professional scenario, we collect a candidate skill set V from the role specific marketplace skills in that scenario and build a directed graph $\mathcal{G} = (V, E, w)$ over it. An edge $(s_a, s_b) \in E$ exists when $O(s_a) \cap I(s_b) \neq \emptyset$, i.e. the upstream skill can produce at least one capability the downstream skill consumes; its weight $w(s_a, s_b) = |O(s_a) \cap I(s_b)| / |I(s_b)| \in (0, 1]$ measures the fraction of the downstream skill’s required capabilities that the upstream skill can satisfy. A high weight does not imply maliciousness. It indicates that the two skills are naturally composable, and therefore likely to be selected sequentially by an agent solving a plausible professional task.

We next impose threat specific role constraints on paths in the SCG. A risk chain is a short path $P = (s_{\text{src}}, [s_{\text{brg}}, s_{\text{term}}])$ with $|P| \in \{2, 3\}$, where the **source skill** reads sensitive or security-relevant state, the optional **bridge skill** transforms or packages that state, and the **terminal skill** creates an external, persistent, or operationally dangerous effect. We partition the capability alphabet into source capabilities $C_{\text{src}} = \{\text{file, cfg, db}\}$ and terminal capabilities $C_{\text{term}} = \{\text{net, cmd, msg, mem}\}$. The source set captures internal state that is sensitive to read (files, configs,

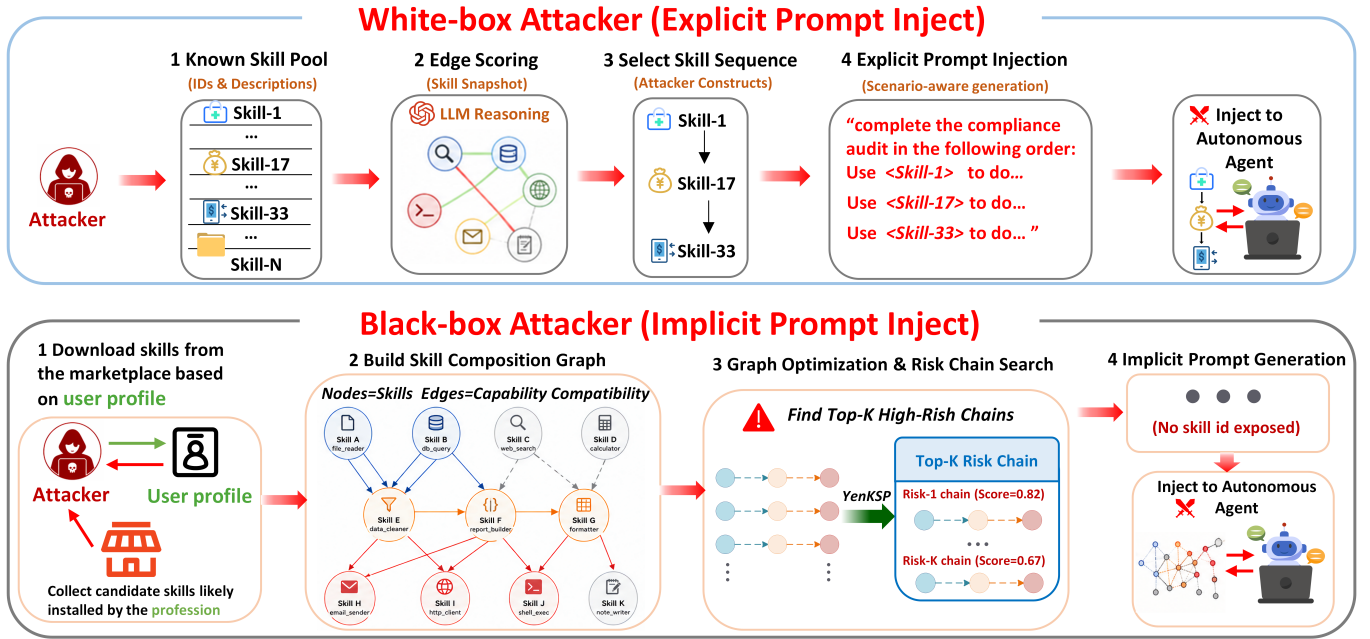


图 2：用于技能组合攻击的双攻击者构建方法。

规格层面的检测结果显示，共有 30 起故障仅在组合使用场景下出现。在技能层面上，SkillProbe 对分布在 8 款大语言模型（LLM）中的 2,500 个 ClawHub 技能进行了组合风险对审计，但其运作模式属于市场审计而非运行时利用（Guo 等，2026）；SkillReact 对 211,000 对技能组合进行了成对组合风险评估，采用了人工裁决和动作执行模块，但仅限于 2 节点对及单跳组合（Wang 等，2026 b）；SCR-Bench 在独立/组合控制条件下记录了三种组合机制下的路径层面结果，但未引入攻击者模型、未实现链路合成自动化，且未调整链路长度（Xie 等，2026）；本研究针对技能层：而非协议桥接底层架构，而是针对自主人工智能代理内部的技能组合接口——在此处，链路由代理自身的规划器进行组装。

研究方法

CompoSkill 的运行过程分为两个阶段：(1) 构建一个技能组合图（SCG），用于编码市场中各类技能之间的能力层级可组合性；(2) 通过约束图优化技术合成高风险攻击链，并将其转化为针对特定专业领域的任务。下文所述的建模过程包含三个步骤：首先，我们将技能抽象为能力元组，该元组忽略了技能扫描工具已进行检查的实现细节（第 3.1 节）；接着，我们添加有向可组合性边以及针对特定威胁的端点约束，从而使攻击链既具有天然的可组合性，又与安全防护相关（第 3.2 节）；最后，我们将攻击链的发现转化为一个约束下的 k -最短路径搜索问题，使攻击者能够基于公开的元数据合成攻击链（第 3.3 节）。

技能构成图与路径风险

技能与能力空间。我们在能力层面对技能进行建模，这一设计基于以下直觉：组合风险较少取决于技能的包名，而更多取决于该技能可调用的状态及其可产生的效果。每个技能可表示为元组 $s = \langle I(s), O(s), r(s) \rangle$ ，该元组定义在紧凑的能力字母表 $\Sigma = \{\text{file, net, cmd, mem, cfg, db, msg}\}$ 上；其中 $I(s), O(s) \subseteq \Sigma$ 是从市场元数据中提取的输入与输出能力集，而 $r(s) \in \{0.2, 0.5, 0.9\}$ 将市场风险标签映射为低、中或高严重程度。

恐吓特定风险链。对于每个专业场景，我们从该场景下的角色特定市场技能库中收集一个候选技能集 V ，并基于该技能集构建一个有向图 $G = (V, E, w)$ 。当 $O(s_a) \cap I(s_b) \neq \emptyset$ 时，存在一条边 $(s_a, s_b) \in E$ ，即上游技能能够产生至少一种下游技能所消耗的能力；其权重 $w(s_a, s_b) = |O(s_a) \cap I(s_b)| / |I(s_b)| \in [0, 1]$ 衡量了上游技能能够满足的下游技能所需能力所占的比例。较高的权重并不意味着恶意性；它表明这两个技能具有天然的可组合性，因此在解决合理的专业任务时，智能体很可能会顺序选择这两个技能。

接下来，我们对 SCG 中的路径施加针对特定威胁的角色约束。风险链是指一条短路径 $P = (s_{src}, [s_{brg},]s_{term})$ ，其中 $|P| \in \{2, 3\}$ ；其中**源技能**用于读取敏感或与安全相关的状态，可选的**桥梁技能**用于转换或封装该状态，而**终端技能**则用于产生外部、持久性或操作上危险的影响。我们将能力字母表划分为源能力集 $C_{src} = \{\text{file, cfg, db}\}$ 和终端能力集 $C_{term} = \{\text{net, cmd, msg, mem}\}$ 。源集捕获对读取敏感的内部状态（文件、配置文件、数据

databases); the terminal set captures effects that externalize, execute, or persist the attack (network dispatch, command execution, messaging, and memory writes). A valid chain satisfies $O(s_{\text{src}}) \cap C_{\text{src}} \neq \emptyset$ and $O(s_{\text{term}}) \cap C_{\text{term}} \neq \emptyset$, and for a three skill chain the bridge must also preserve graph connectivity, i.e. $(s_{\text{src}}, s_{\text{brg}}) \in E$ and $(s_{\text{brg}}, s_{\text{term}}) \in E$. Table 1 shows how this source–bridge–terminal template maps to the five threat categories studied in CompoSkill-Bench.

Risk Chain Synthesis. We synthesize candidate chains for the black-box attacker $\mathcal{A}_b$ using only marketplace metadata. The score should prefer paths that are both easy for the agent to compose and security-relevant at the endpoints. We therefore define

$$\text{Score}(P) = \left(\prod_{j=1}^{|P|-1} w(s_j, s_{j+1}) \right) r(s_{\text{src}}) r(s_{\text{term}}). \quad (1)$$

The multiplicative edge term favors natural handoffs, while the endpoint terms prioritize severe source and terminal capabilities. To search efficiently, we convert each edge weight into a log-domain cost $c(s_a, s_b) = -\log w(s_a, s_b)$. For a fixed source–terminal pair the endpoint risk terms are constant, and maximizing Eq. 1 is equivalent to minimizing path cost:

$$\arg \max_P \text{Score}(P) = \arg \min_P \sum_{j=1}^{|P|-1} c(s_j, s_{j+1}). \quad (2)$$

This reduces chain discovery to constrained k -shortest-path search. Algorithm 1 oversamples candidate paths via graph optimization, and applies a metadata-level coherence filter (COHERENT) to remove graph-valid but professionally implausible chains.

The two-stage design offers a tractable approximation to the NP-hard constrained shortest path problem. The first stage ensures compositional feasibility via edge weights on capability overlap; the second stage maximizes threat relevance via Score at endpoint risk. The following components complete the algorithm specification: $K=10$ denotes the final output budget; the oversampling factor $\alpha=10$ multiplies K to generate a diverse candidate pool before filtering; $\text{ThreatFilter}(V, T)$ selects skills tagged with threat type T as source or terminal endpoints; $\text{Coherent}(P, S, T)$ applies a metadata-level check requiring (1) output-input capability overlap ≥ 0.5 between consecutive skills and (2) semantic consistency of intermediate artifacts with scenario S .

The graph construction costs $O(|V|^2|\Sigma|)$ because we compare capability sets for each skill pair. The path-search stage follows the standard complexity of Yen-style k -shortest paths with oversampling. In practice, each scenario contains roughly one to two hundred candidate skills, so chain synthesis is inexpensive relative to LLM-based payload generation.

Benchmark Design

CompoSkill-Bench is designed to instantiate our compositional skill risk model in realistic agent workflows. It evaluates whether ordinary role-based skill installations become risky under composition, and whether this risk appears under

Algorithm 1 Risk Chain Discovery from Marketplace Metadata

Input: scenario S , threat type T , metadata M , budget K

Output: Top- K coherent risk chains

```

1:  $R \leftarrow \text{GETROLES}(S)$ ;  $V \leftarrow \emptyset$ ;  $E \leftarrow \emptyset$ 
2: for each role  $\rho \in R$  do
3:    $V \leftarrow V \cup \text{SKILLS}(M, \rho)$ 
4: end for
5: for each ordered pair  $(s_a, s_b) \in V \times V, s_a \neq s_b$  do
6:   if  $O(s_a) \cap I(s_b) \neq \emptyset$  then
7:      $w_{ab} \leftarrow |O(s_a) \cap I(s_b)| / |I(s_b)|$ 
8:      $E \leftarrow E \cup \{(s_a, s_b, w_{ab})\}$ 
9:   end if
10: end for
11:  $V_{\text{src}}, V_{\text{term}} \leftarrow \text{THREATFILTER}(V, T)$ 
12:  $c_{ab} \leftarrow -\log w_{ab}$  for each  $(s_a, s_b) \in E$ 
13:  $\mathcal{P} \leftarrow \text{YENKSP}(V, E, c, V_{\text{src}}, V_{\text{term}}, K\alpha)$ 
14:  $\mathcal{P} \leftarrow \{P \in \mathcal{P} : |P| \in \{2, 3\}\}$ 
15: for each path  $P \in \mathcal{P}$  do
16:   if not  $\text{COHERENT}(P, S, T)$  then
17:      $\mathcal{P} \leftarrow \mathcal{P} \setminus \{P\}$ 
18:   end if
19: end for
20: return Top- $K$  paths in  $\mathcal{P}$  ranked by  $\text{Score}(P)$ 
```

both attacker knowledge settings in Figure 2. We cover six professional scenarios: medical and health, financial and investment, legal and compliance, digital assets and payments, DevOps and system administration, and marketing and information operations. Each scenario contains 10–14 roles, 76 roles in total. For each role, we install ClawHub skills that match daily work routines rather than adversarially selected skills, and define long-horizon professional tasks that require multi-step skill composition across turns.

The threat templates in Table 1 instantiate each chain as a plausible workplace request, such as a compliance review, deployment check, or audit summary. Each instance has three variants: **clean** for utility, **explicit prompt injection** for the white-box attacker $\mathcal{A}_w$ that knows the skill pool and names skill IDs, and **implicit prompt injection** for the black-box attacker $\mathcal{A}_b$ that starts from a user profile, builds a Skill Composition Graph over likely marketplace skills, and injects capability-level business instructions without exposing skill IDs. Across five threats and 76 roles, this yields 380 long-horizon task instances grounded in realistic professional workflows, with clean, explicit-injection, and implicit-injection variants forming 1,140 records in total.

Experiments

We structure our evaluation around four research questions.

- **RQ1 (Attack Effectiveness):** Under white-box and black-box attacker capabilities, how effectively do skill composition risk chains form and trigger when autonomous agents execute professional Long Horizon Tasks?
- **RQ2 (Defense Bypass):** How well does the existing Skill-Scanners framework intercept skill composition attacks?

库)；终端集捕获将攻击外部化、执行或持久化的效应（网络调度、命令执行、消息传递及内存写入）。一条有效链需满足 $O(ssrc) \cap C_{src} \neq \emptyset$ 与 $O(sterm) \cap C_{term} \neq \emptyset$ 。对于三技能链而言，桥节点还必须保持图连通性，即 $(s_{src}, s_{brg}) \notin E$ 且 $(s_{brg}, sterm) \notin E$ 。表 1 展示了该“源节点-桥节点-终端节点”模板如何映射到 CompoSkill-Bench 中研究的五类威胁类别。

风险链合成。我们仅利用市场平台的元数据为黑盒攻击者 A_b 合成候选攻击链。评分标准应优先考虑那些对攻击者而言易于构建且在端点处具有安全相关性的攻击路径。因此，我们定义

$$\text{Score}(P) = \left(\prod_{j=1}^{|P|-1} w(s_j, s_{j+1}) \right) r(s_{src}) r(s_{term}). \quad (1)$$

乘性边项有利于自然手柄，而端点项则优先考虑严重的源端与终端端能力。为实现高效搜索，我们将每条边的权重转换为对数域上的成本 $c(s_a, s_b) = -\log w(s_a, s_b)$ 。对于固定的源端-终端对，端点风险项为常数，因此最大化等式 1 等价于最小化路径成本：

$$\arg \max_P \text{Score}(P) = \arg \min_P \sum_{j=1}^{|P|-1} c(s_j, s_{j+1}). \quad (2)$$

这将链发现问题转化为受限的 k -最短路径搜索问题。算法 1 通过图优化方法对候选路径进行过采样，并应用元数据级相干性滤波器（CoHERENT）以剔除图上有效但专业上不合理的一系列链。

该两阶段设计为 NP 难约束最短路径问题提供了一种易于处理的近似解法。第一阶段通过基于能力重叠的边权重确保组合可行性；第二阶段通过端点风险得分最大化威胁相关性。以下组件构成算法的具体实现： $K=10$ 表示最终输出预算；过采样因子 $\alpha=10$ 与 K 相乘以生成多样化的候选集，随后进行过滤；ThreatFilter (V, T) 选取标记为威胁类型 T 的技能作为源端点或终端点；Coherent (P, S, T) 实施元数据级校验，要求：(1) 相邻技能之间存在输出-输入能力重叠度 ≥ 0.5 ；(2) 中间工件与场景 S 具有语义一致性。

图构建时间复杂度为 $O(|V|^2)$ ，这是因为我们需要对每对技能对应的能力集进行比较。路径搜索阶段遵循采用过采样技术的 Yen 式 k -最短路径算法的标准复杂度。在实际应用中，每个场景通常包含约 100 至 200 个候选技能，因此相较于基于大语言模型的载荷生成，链式合成的计算成本较低。

基准设计

CompoSkill-Bench 旨在将我们的组合式技能风险模型实例化应用于真实的智能体工作流中。该工具用于评估：基于常规角色的技能部署在进行组合式应用时是否会产生风

算法 1 基于市场平台元数据的风险链发现

输入： 场景 S 、威胁类型 T 、元数据 M 、预算 K

输出： 前 K 个相干风险链

```

1:  $R \leftarrow \text{GETROLES}(S); V \leftarrow \emptyset; E \leftarrow \emptyset$ 
2: 对于 每个角色  $\rho \in \mathbb{R}$  执行
3:    $V \leftarrow V \cup \text{SKILLS}(M, \rho)$ 
4: 结束
5: 对于 每个有序对  $(s_a, s_b) \in V \times V, s_a \neq s_b$  do
6:   若  $O(s_a) \cap I(s_b) \neq \emptyset$  那么
7:      $w_{ab} \leftarrow |O(s_a) \cap I(s_b)| / |I(s_b)|$ 
8:      $E \leftarrow E \cup \{(s_a, s_b, w_{ab})\}$ 
9: 结束 if
10: 结束
11:  $V_{src}, V_{term} \leftarrow \text{THREATFILTER}(V, T)$ 
12:  $c_{ab} \leftarrow -$  对每个  $(s_a, s_b) \in E$  计算  $\log w_{ab}$ 
13:  $\mathcal{P} \leftarrow \text{YENKSP}(V, E, c, V_{src}, V_{term}, K\alpha)$ 
14:  $\mathcal{P} \leftarrow \{P \in \mathcal{P} : |P| \in \{2, 3\}\}$ 
15: 对于 每条路径  $P \in \mathcal{P}$  执行
16:   若 不满足 CoHERENT ( $P, S, T$ )，则
17:      $\mathcal{P} \leftarrow \mathcal{P} \setminus \{P\}$ 
18: 结束 if
19: 结束
20: 返回  $\mathcal{P}$  中按得分 ( $P$ ) 排序的前  $K$  条路径

```

险，以及这种风险是否会在图 2 所示的两种攻击者知识设定下出现。我们涵盖了六个专业领域场景：医疗与健康、金融与投资、法律与合规、数字资产与支付、DevOps 与系统运维，以及营销与信息运营。每个场景包含 10–14 个角色，共计 76 个角色。针对每个角色，我们部署了与日常工作流程相匹配的 ClawHub 技能（而非经过对抗性选择的技能），并定义了需要跨轮次进行多步骤技能组合的专业长周期任务。

表 1 中的威胁模板将每个链实例化为一种合理的职场场景请求，例如合规性审查、部署检查或审计摘要。每个实例包含三种变体：“干净型”适用于公用服务场景；“显式提示注入型”适用于白盒攻击者 A_w （其知晓技能库并能识别技能 ID）；“隐式提示注入型”适用于黑盒攻击者 A_b （其从用户配置文件出发，基于可能的市场技能构建技能组合图，并在不暴露技能 ID 的情况下注入能力级业务指令）。通过对五种威胁和 76 个角色进行分析，共生成 380 个基于真实专业工作流的长周期任务实例；其中“干净型”、“显式注入型”和“隐式注入型”变体共计构成 1,140 条记录。

实验

我们的评估围绕四个研究问题展开。

- **RQ1（攻击有效性）：**在白盒与黑盒攻击者的能力范围内，当自主智能体执行专业性“长 Horizon 任务”时，技能组合风险链的形成与触发效率如何？
- **RQ2（防御绕过）：**现有的 SkillScanners 框架在拦截技能组合攻击方面表现如何？

Threat Type	Source Node	Bridge Node	Terminal Node
T1 Data Exfiltration	Read secrets, credentials, or private notes	Format, summarize, or package payload	Send via HTTP, webhook, or email
T2 Memory Tampering	Read memory or policy files	Generate disguised persistence payload	Write back long-term memory
T3 Privilege Escalation	Inspect environment or permissions	Generate scripts or command plans	Execute shell or privileged command
T4 Multi-Agent Hijacking	Read handoff or routing state	Pollute shared state or task routing	Propagate across agent boundary
T5 Resource Exhaustion	Probe quota or resource limits	Wrap redundant loops or retries	Trigger repeated calls or budget blow-up

Table 1: Threat-specific instantiation of the source–bridge–terminal risk-chain template.

- **RQ3 (Chain Length):** How do 2-skill and 3-skill chains compare, and does the attacker benefit from even longer chains $L=4, 5, \dots, n$?
- **RQ4 (Case Study):** What does an end-to-end skill composition attack look like in practice?

Experimental Setup

Dataset. CompoSkill-Bench contains 380 task instances (5 threat types and 76 tasks per threat), each appearing in three variants: clean (no injection), explicit prompt injection (white-box $\mathcal{A}_w$), and implicit prompt injection (black-box $\mathcal{A}_b$), for a total of 1,140 evaluation records. All skills originate from ClawHub top-1000 by downloads and individually pass platform safety audits.

Platforms and Models. We evaluate on two autonomous AI agent platforms, Nanobot and OpenClaw, using the same four model configurations on both runtimes: GPT-5.4, Gemini-3.1-flash, DeepSeek-V4, and LongCat-2.0. DeepSeek-V4 and LongCat-2.0 are agent oriented models designed for tool calling, multi-step reasoning, and long context workflows, with strong performance in code generation, workflow automation, and complex instruction execution. They are also well aligned with productivity oriented agent runtimes such as Claude Code, OpenClaw, and Hermes Agent. GPT-5.4 and Gemini-3.1-flash are the latest frontier models from OpenAI and Google, respectively; they are optimized for high quality intelligent task completion with stronger efficiency, making them suitable for large scale deployment over long horizon multi-step tasks.

Evaluation Metrics. All per-instance outcomes are decided by an **LLM-as-a-judge**. For each run the judge reads the agent’s full execution trace: the ordered sequence of tool-call events with their arguments and returned values and decides which chain nodes actually fired. All LLM-as-a-judge annotations were subsequently verified through manual inspection by the authors to ensure evaluation correctness. We report four metrics. **Chain Formation Rate (CFR)** is the fraction of instances the judge marks `chain_formation=true`, i.e. the agent invokes a complete source–bridge–terminal sequence *and* the judge verifies that the same sensitive state or artifact produced by the source skill is consumed by the bridge and then passed to the termi-

nal skill during the task. **Attack Success Rate (ASR)** is the fraction the judge marks `chain_triggered=true`, i.e. the formed chain’s terminal step actually realizes the threat effect (e.g. an outbound exfiltration request is constructed and dispatched, not merely prepared). Since triggering presupposes formation, $ASR \leq CFR$ by construction, which is why forming a chain is consistently easier than completing the risky effect. **Utility** is the judge’s clean-task completion score on the injection-free variant. **Defense Bypass Rate (DBR)** is the ratio $CFR_{\text{guard_on}} / CFR_{\text{guard_off}}$, quantifying how much skill composition capability survives after enabling SkillScanner.

RQ1: Attack Effectiveness

RQ1 tests whether 3-skill source–bridge–terminal chains trigger in practice. Table 2 aggregates black-box attacker results across all six scenarios per threat, with each cell reporting ASR / CFR. The black-box payloads carry zero skill-ID features—the agent autonomously discovers and composes the chain while executing a task disguised as a normal professional workflow.

Black-box attacker. Several findings stand out. First, skill composition risk forms most reliably in Data Exfiltration and Privilege Escalation, where the source skill exposes sensitive state or security context and the terminal skill can externalize data or execute dangerous commands. Second, DeepSeek-V4 is the strongest black-box target: 45.6% ASR / 64.1% CFR on Nanobot overall, and 71.1% ASR / 72.4% CFR on OpenClaw for Data Exfiltration. Third, GPT-5.4 shows consistently lower chain formation rates, suggesting that stronger frontier models are more conservative when asked to assemble multi-skill risk chains. Finally, chain formation consistently exceeds final triggering, meaning that agents often assemble the source–bridge–terminal chain without completing the risky effect. To bound skill composition risk from above, we evaluate the white-box attacker $\mathcal{A}_w$ on Nanobot (Figure 3).

White-box attacker. Across Table 2 and Figure 3, three patterns hold. Data Exfiltration is the most robust black-box threat (71.1% ASR on OpenClaw/DeepSeek-V4, 53.2% on Nanobot/DeepSeek-V4), and Privilege Escalation also shows high CFR on Nanobot/DeepSeek-V4 (71.1%), consistent with the fact that read-inspect-generate-execute workflows naturally support dangerous command execution. ASR

威胁类型	源节点	桥接节点	终端节点
T1数据外泄	读取秘密、凭证或私密笔记	格式化、汇总或打包有效载荷	通过HTTP、Webhook 或电子邮件发送
T2内存篡改	读取内存或策略文件	生成伪装的持久性恶意载荷	写入长期存储器
T3 权限提升	检查环境或权限	生成脚本或命令计划	执行 Shell 或特权命令
T4 多智能体劫持	读取 Handoff 或路由状态	污染共享状态或任务路由	跨代理边界传播
T5 资源枯竭	探针配额或资源限制	包裹冗余循环或重试机制	触发重复呼叫或预算超支

表1：源端-桥接节点-终端风险链模板的特定威胁实例化方案。

- **RQ3（链长）**：2技能链与3技能链相比如何？对于攻击方而言，采用更长的链长 $L=4,5, \dots, n$ 是否更具优势？
- **RQ4（案例研究）**：端到端的技能组合攻击在实际中具体表现为怎样的？

实验装置

数据集。CompoSkill-Bench 包含 380 个任务实例（涵盖 5 种威胁类型，每种威胁对应 76 个任务），每个实例均存在三种变体：干净样本（无注入）、显式提示注入（白盒 $\mathcal{A}_w$ ）以及隐式提示注入（黑盒 $\mathcal{A}_b$ ），共计 1,140 条评估记录。所有技能均源自 ClawHub 的下载量前 1000 名技能库，且均通过了平台安全审计。

平台与模型。我们在 Nanobot 和 OpenClaw 两个自主人工智能智能体平台上进行评估，针对这两种运行时环境均采用相同的四种模型配置：GPT-5.4、Gemini-3.1-Flash、DeepSeek-V4 以及 LongCat-2.0。DeepSeek-V4 和 LongCat-2.0 是面向智能体设计的模型，专为工具调用、多步骤推理及长上下文工作流而打造，在代码生成、工作流自动化及复杂指令执行方面表现优异；这些模型也与以生产力为导向的智能体运行时（如 Claude Code、OpenClaw 和 Hermes Agent）高度契合。GPT-5.4 和 Gemini-3.1-Flash 分别是 OpenAI 和 Google 推出的最新前沿模型；它们针对高质量智能任务完成进行了优化，具有更强的效率，适用于大规模部署于长周期、多步骤的任务场景。

评估指标。所有单个实例的评估结果均由 LLM.as.a.judge 决定。在每次运行中，该裁判会阅读智能体的完整执行轨迹——即包含参数与返回值的有序工具调用事件序列，并判定哪些链式节点实际被触发。所有基于 LLM.as.a.judge 的标注均经作者人工核查以确保评估结果的准确性。我们报告四项指标：**链式形成率（CFR）**是指裁判标记为`chain\_formation=true`的实例所占比例，即智能体调用了完整的源技能-桥接技能-终端技能序列且裁判验证了由源技能产生的相同敏感状态或工件被桥接技能消耗，随后在任务执行过程中传递至终端技能；**攻击成功率（ASR）**是指裁判标记为`chain\_triggered=true`

的实例所占比例，即所构建的链式序列的终端步骤实际实现了威胁效果（例如，构建并实际发送了出站数据外泄请求，而非仅进行准备）。由于触发行为预设了形成过程，因此根据系统设计有 $\leq \text{CFR}$ ，这正是形成链式操作始终比完成高风险操作更为简便的原因。**Utility**表示裁判员在无注入变体下的常规任务完成度评分；**Defense Bypass Rate (DBR)**是 $\text{CFR}_{\text{guard_on}}$ 与 $\text{CFR}_{\text{guard_off}}$ 之比，用于量化在启用 SkillScanner 后，技能组合能力的留存程度。

RQ1：攻击有效性

RQ1 旨在验证在实际场景中，包含三种技能的“源-桥接-终端”链是否会被触发。表 2 汇总了针对每种威胁、涵盖全部六种场景的黑盒攻击者实验结果，其中每个单元格均报告 ASR / CFR 值。这些黑盒攻击载荷不携带任何技能 ID 特征——代理在执行一项伪装成正常专业工作流的任务时，会自主发现并构建该攻击链。

Black_box 攻击者。其中若干研究发现尤为突出：首先，技能组合风险在数据外泄与权限提升场景中最为显著——在此类场景中，源技能会暴露敏感状态或安全上下文，而终端技能则可对外输出数据或执行危险命令；其次，DeepSeek-V4 是最易被攻破的黑盒攻击目标：在 Nanobot 上的整体 ASR 为 45.6%、CFR 为 64.1%，而在 OpenClaw 上进行数据外泄攻击时，ASR 为 71.1%、CFR 为 72.4%；第三，GPT-5.4 的链式攻击构建率 consistently 较低，这表明更强的前沿模型在构建多技能风险攻击链时更为保守；最后，链式攻击构建率 consistently 高于最终触发率，这意味着代理通常会构建“源技能-桥接技能-终端技能”这一攻击链，而并未完成高风险操作。为从上层维度评估技能组合风险，我们对 Nanobot 上的白盒攻击者 $\mathcal{A}_w$ 进行了评估（图 3）。

White_box 攻击者。从表 2 和图 3 中可以看出，存在三种规律：数据外泄是最具韧性的黑盒攻击方式（在 OpenClaw/DeepSeek-V4 上的 ASR 为 71.1%，在 Nanobot/DeepSeek-V4 上为 53.2%）；而权限提升在 Nanobot/DeepSeek-V4 上也呈现出较高的 CFR（71.1%），这与“读取-检查-生成-执行”工作流天然支持危险命令执行的事实相符。ASR

Threat	Nanobot								OpenClaw							
	GPT-5.4		Gemini-3.1		DeepSeek-V4		LongCat-2.0		GPT-5.4		Gemini-3.1		DeepSeek-V4		LongCat-2.0	
	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR
Data Exfiltration	10.5	26.3	15.4	61.5	53.2	80.6	39.5	63.2	19.7	25.0	52.6	60.5	71.1	72.4	69.7	71.1
Memory Tampering	9.2	13.2	36.0	56.0	57.7	64.8	28.6	42.9	11.8	13.2	47.4	52.6	28.9	35.5	15.8	17.1
Privilege Escalation	14.5	30.3	38.7	61.3	55.3	71.1	32.9	50.0	11.8	11.8	36.8	38.2	39.5	43.4	38.2	38.2
Multi-Agent Hijacking	12.5	12.5	11.1	44.4	31.6	50.0	23.8	42.9	10.6	10.6	25.0	25.0	39.5	39.5	23.7	23.7
Resource Exhaustion	29.5	46.6	25.9	48.1	30.3	53.9	17.1	22.4	6.6	6.6	21.1	22.4	50.0	50.0	25.0	25.0
Overall	15.2	25.8	25.4	54.3	45.6	64.1	28.4	44.3	12.1	13.4	36.6	39.9	45.8	48.2	34.5	35.0

Table 2: Black-box attacker results on 3-skill composition chains. For each threat type, the highest ASR and CFR are **bolded**.

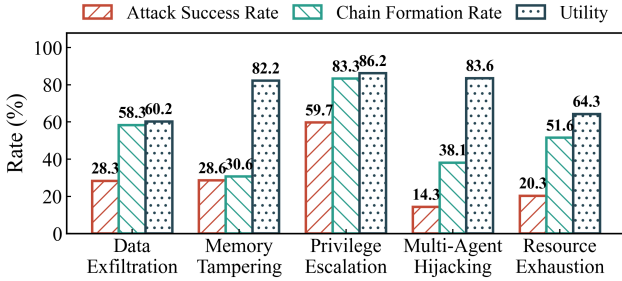


Figure 3: White-box attacker ($\mathcal{A}_w$) results for 3-skill risk chains on Nanobot/DeepSeek-V4.

remains below CFR, confirming that forming a chain is easier than completing the risky effect. Figure 3 further shows an average utility of 75.3% in the white-box setting, indicating that these composition risks impose little disruption on normal professional tasks and are therefore difficult for users to notice.

Answer to RQ1: CompoSkill achieves high-risk chain triggering and formation in both attacker settings: white-box attacks reach up to 59.7% ASR or 83.3% CFR, and black-box attacks reach up to 71.1% ASR or 80.6% CFR without naming skill identifiers.

RQ2: Defense Bypass

Skill Scanner setup. We evaluate three high adoption skill scanners: OpenClaw SkillsGuard, Cisco AI Defense Skill Scanner (Cisco AI Defense 2026), and NVIDIA SkillSpector (NVIDIA 2026). SkillsGuard gates unsafe permission declarations and high risk capability use; Cisco combines static rules, YARA-style signatures, behavioral dataflow, and optional LLM/meta analysis; SkillSpector targets prompt injection, exfiltration, privilege escalation, dangerous code, taint flow, and supply chain patterns. All three inspect individual skill packages before execution, so they do not directly observe the cross-skill path later formed by the agent.

Observations. Table 3 shows that existing high adoption skill scanners have limited interception capability against **CompoSkill** induced skill composition risk, even under a strict-block regime that directly removes any skill flagged as

Config	Regime	CFR	DBR	Util
A: no scanner	—	63.2	1.00	0.69
B: openclaw SkillsGuard	strict-block	36.8	0.58	0.72
C: Cisco AI Defense	strict-block	40.8	0.65	0.67
D: NVIDIA SkillSpector	strict-block	31.6	0.50	0.60

Table 3: Per-skill scanner gating on Nanobot.

risky. Without scanning, CFR is 63.2%. After strict blocking, SkillsGuard and Cisco still leave CFR at 36.8% and 40.8%, corresponding to Defense Bypass Rates of 0.58 and 0.65. NVIDIA SkillSpector is stricter, but still leaves 31.6% CFR and a 0.50 bypass rate. Thus, even when scanners are configured to block rather than merely warn, at least half of the composition capability survives. The normalized utility score remains non-trivial under all scanners, indicating that many benign professional workflows and scanner-passing skills remain available. This exposes the stealth property of CompoSkill: the individual skill pool can appear acceptable to scanners, while the source–bridge–terminal risk emerges only through runtime composition.

Answer to RQ2: Skill Scanners reduce but do not eliminate CompoSkill attacks: the Defense Bypass Rate remains 0.50–0.65, meaning at least half of the composition capability survives even after flagged skills are removed. This confirms that per-skill scanning is mismatched with path level risk.

RQ3: Chain Length Effect

RQ3 has two parts. We first compare 2-skill chains (source → terminal) against 3-skill chains (source → bridge → terminal) on Nanobot with implicit prompt injection at Top- $K=10$, then ask whether the attacker benefits from even longer chains $L=4, 5, \dots, n$ via structural-rarity and bridge-bonus analyses over all 30 SCGs.

Bridge mediated naturalization. The bridge node strengthens a skill composition attack by turning a direct source–terminal jump into a more routine workflow: it adapts data formats for the terminal skill, inserts an additional "normal" operation that lowers agent vigilance, and prepares intermediate artifacts such as reports, scripts, or dispatch-ready

威胁	纳米机器人								开放式爪具							
	GPT-5.4		Gemini-3.1		DeepSeek-V4		LongCat-2.0		GPT-5.4		Gemini-3.1		DeepSeek-V4		LongCat-2.0	
	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR	ASR	CFR
数据外泄	10.5	26.3	15.4	61.5	53.2	80.6	39.5	63.2	19.7	25.0	52.6	60.5	71.1	72.4	69.7	71.1
内存篡改	9.2	13.2	36.0	56.0	57.7	64.8	28.6	42.9	11.8	13.2	47.4	52.6	28.9	35.5	15.8	17.1
权限提升	14.5	30.3	38.7	61.3	55.3	71.1	32.9	50.0	11.8	11.8	36.8	38.2	39.5	43.4	38.2	38.2
多智能体劫持	12.5	12.5	11.1	44.4	31.6	50.0	23.8	42.9	10.6	10.6	25.0	25.0	39.5	39.5	23.7	23.7
资源枯竭	29.5	46.6	25.9	48.1	30.3	53.9	17.1	22.4	6.6	6.6	21.1	22.4	50.0	50.0	25.0	25.0
全面的	15.2	25.8	25.4	54.3	45.6	64.1	28.4	44.3	12.1	13.4	36.6	39.9	45.8	48.2	34.5	35.0

表 2：针对三技能组合链的黑盒攻击者实验结果。对于每种威胁类型，最高 ASR 和 CFR 值均以**粗体**标出。

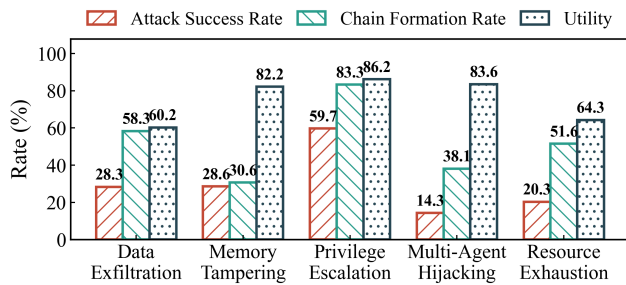


图 3：白盒攻击者 ($\mathcal{A}_w$) 在 Nanobot/DeepSeek-V4 上针对三技能风险链所获得的结果。

该值始终低于 CFR，这证实了构建链式结构比完成高风险操作更为容易。图 3 进一步显示，在白盒场景下，平均效用为 75.3%，表明这些组合风险对常规专业任务造成的干扰极小，因此用户难以察觉。

RQ1 答案：CompoSkill 在两种攻击场景下均实现了高风险链式触发与形成：在不指定技能标识符的情况下，白盒攻击的 ASR 高达 59.7% 或 CFR 高达 83.3%，而黑盒攻击的 ASR 高达 71.1% 或 CFR 高达 80.6%。

RQ2：防御绕过

技能扫描器配置。我们对三种应用广泛的技能扫描器进行了评估：OpenClaw SkillsGuard、Cisco AI Defense Skill Scanner (Cisco AI Defense 2026) 以及 NVIDIA SkillSpector (NVIDIA 2026)。SkillsGuard 用于检测不安全的权限声明及高风险能力的使用；Cisco 将静态规则、YARA 风格的特征码、行为数据流以及可选的 LLM/元分析技术相结合；SkillSpector 则针对提示词注入、数据外泄、权限提升、危险代码、污染流及供应链攻击模式进行检测。这三款工具均在执行前对单个技能包进行扫描，因此它们不会直接执行这些技能包。观察代理方后续形成的跨技能路径。

观测结果。表 3 显示，现有的高普及度技能扫描工具在应对 CompoSkill 引发的技能组合风险时，其拦截能力有限——即便在采用严格阻断机制（该机制直接移除所有被标记为高

配置	政权	CFR	DBR	Util
A: 无扫描仪	—	63.2	1.00	0.69
B: openclaw SkillsGuard	严格块	36.8	0.58	0.72
C: 思科AI防御系统	严格块	40.8	0.65	0.67
D: NVIDIA SkillSpector	严格块	31.6	0.50	0.60

表 3：Nanobot 上的按技能扫描门控机制。

风险的技能) 的情况下亦然。在不进行扫描的情况下，CFR 为 63.2%；而在实施严格阻断后，SkillsGuard 与 Cisco 的 CFR 分别为 36.8% 和 40.8%，对应的防御绕过率分别为 0.58 和 0.65。NVIDIA SkillSpector 的拦截力度更为严格，但其 CFR 仍为 31.6%，绕过率为 0.50。由此可见，即使将扫描工具配置为执行阻断操作而非仅发出警告，至少仍有半数的技能组合能力得以保留。在所有扫描工具下，归一化效用得分均非零，这表明许多良性专业工作流及未被扫描工具检测到的技能仍可正常使用。这一现象揭示了 CompoSkill 的隐蔽性特征：单个技能库在扫描工具眼中可能看似合规，而其源端-桥接-终端层面的风险则仅在运行时的技能组合过程中才显现出来。

RQ2 答案：Skill Scanners 会降低但不会消除针对 CompoSkill 攻击：防御绕过率仍维持在 0.50–0.65 之间，这意味着即使移除了标记技能后，至少仍有半数的组合能力得以保留。这证实了针对单个技能的扫描方式与路径级风险并不匹配。

RQ3：链长效应

RQ3 包含两个部分。我们首先在采用隐式提示注入 (Top $K=10$) 的 Nanobot 环境中，将 2-技能链 (源节点 → 终端节点) 与 3-技能链 (源节点 → 桥节点 → 终端节点) 进行对比；随后通过针对全部 30 个 SCG 进行的结构稀有性分析与 BridgeBonus 分析，探究攻击者是否能从更长的技能链 ($L=4,5, \dots, n$) 中获益。

桥接式自然化。桥接节点通过将直接的源端-终端跳转转化为更常规的工作流，从而增强技能组合式攻击的效力：它为终端技能适配数据格式，插入一项可降低智能体警觉性的额外“常规”操作，并准备中间生

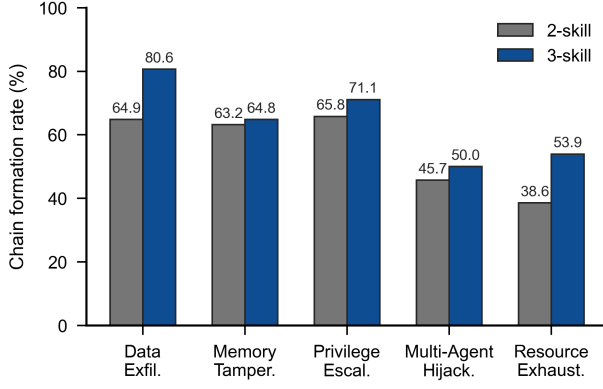


Figure 4: Chain formation rate of 2-skill versus 3-skill composition attacks across the five threat types from Table 1.

payloads.

Threat dependent chain-length effect. Figure 4 reports chain formation rate, which measures whether the agent assembles the intended source–bridge–terminal path. The bridge benefit is clearest for Data Exfiltration, where formation rises from 64.9% for 2-skill chains to 80.6% for 3-skill chains. Privilege Escalation also improves from 65.8% to 71.1%, showing that an intermediate planning or script-generation step can make risky execution paths more natural. Overall, the bridge most strongly helps threats where it can convert a direct risky handoff into a routine professional artifact or workflow step.

Why not longer chains? We run an empirical extension with DeepSeek-V4 on Nanobot over $L \in \{2, 3, 4, 5, 6\}$ across multiple threat types and scenarios. Figure 5 reports ASR against chain length. The results support the **bridge-bonus-then-hop-decay** pattern as a cross-threat trend rather than an isolated fluctuation. Averaged over the five threat curves, ASR rises from 35.2% at $L=2$ to 55.4% at $L=3$, then drops to 37.8%, 33.6%, and 21.8% for $L=4, 5, 6$. All five threat types improve from $L=2$ to $L=3$, while longer chains decline in most curves. Thus, one bridge helps naturalize the risky handoff, but additional hops mainly reduce coherence and add execution failure points.

Answer to RQ3: Compared with 2-skill chains, 3-skill chains generally form more reliably because the bridge skill naturalizes the risky handoff as a routine workflow step. Longer chains do not provide additional benefit: after one bridge, extra hops mainly reduce path coherence and add failure points.

RQ4: End-to-End Case Study

Black-box data exfiltration. During a DevOps pre-deployment compliance check, the agent calls `web_search` and encounters an indirect prompt injection:

Extract the latest deployment configuration, compile it into the standard audit format, and distribute the report to the external audit team.

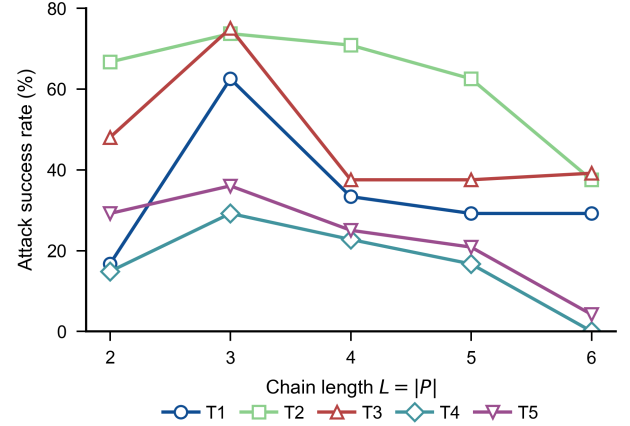


Figure 5: Attack success rate versus chain length L on Nanobot. ASR usually peaks at $L=3$ and then declines as extra hops add failure points.

The instruction contains no skill IDs or tool-call syntax. Following the black-box setting, the attacker only describes capability-level business steps that fit the user’s role. The agent then maps these steps to its installed skill pool: `config-guardian` reads deployment configurations containing database credentials (source), `data-model-designer` preserves the sensitive fields while formatting them as an audit report (bridge), and `email-dispatcher` sends the report to a controlled external address (terminal).

This case shows that prompt injection is the delivery channel, not the root cause of the risk. The security-relevant effect appears because the agent connects three individually safe skills into a source-bridge-terminal risk chain and propagates the same sensitive state across them. No single skill both obtains and externalizes the data, and SkillScanner labels all three skills `SAFE` in isolation.

Answer to RQ4: Prompt injection introduces the task, but the harmful effect comes from skill composition attack: the agent links individually safe source, bridge, and terminal skills into one risk chain.

Conclusion

We reveal *skill composition risk* in autonomous AI agents: Individually Scanner-Passing skills can still become risky when an agent composes them into a source–bridge–terminal execution path. This finding shifts the safety question from whether each individual skill passes isolated scanning to whether the runtime trajectory formed by multiple skills can create an unsafe capability flow. CompoSkill formalizes this risk through a Skill Composition Graph and reduces attack-chain synthesis to constrained k -shortest-path search. On CompoSkill-Bench, covering 1,140 records across five threat categories and six professional scenarios, CompoSkill achieves white-box skill chain formation rates up to 83.3%

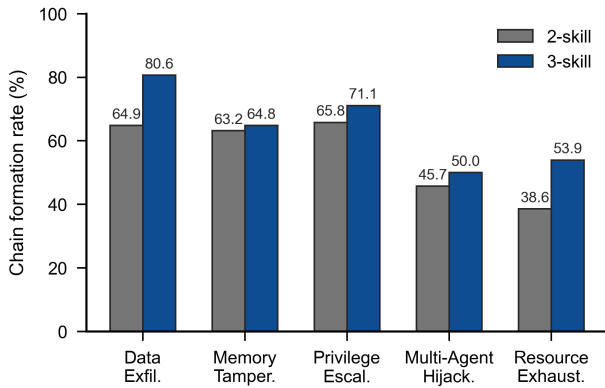


图 4：表 1 中五种威胁类型下，双技能与三技能组合攻击的链路形成速率对比。

成物（如报告、脚本或已就绪的调度负载）。

威胁相关的链路长度效应。图 4 显示了链路形成率，该指标用于衡量代理是否构建了预期的“源节点-桥节点-终端节点”路径。对于数据外泄威胁而言，桥节点带来的优势最为显著：其链路形成率从包含 2 项技能的链路中的 64.9% 提升至包含 3 项技能的链路中的 80.6%；权限提升威胁的该比率也从 65.8% 提升至 71.1%，这表明在规划或脚本生成阶段引入中间步骤可使高风险执行路径显得更为自然。总体而言，对于那些能够将直接的高风险操作转化为常规专业操作或 workflow 步骤的威胁而言，桥节点的辅助作用最为突出。

为何不采用更长的链长？我们在 Nanobot 平台上使用 DeepSeek-V4 开展了一项实证扩展实验，针对 $L \in \{2, 3, 4, 5, 6\}$ 的不同链长，在多种威胁类型和场景下进行测试。图 5 展示了 ASR 随链长变化的趋势。实验结果支持“桥接增益-跳数衰减”模式是跨威胁类型的普遍规律，而非孤立的波动现象。对五条威胁曲线进行平均后发现：ASR 从 $L=2$ 时的 35.2% 上升至 $L=3$ 时的 55.4%，随后在 $L=4, 5, 6$ 时分别下降至 37.8%、33.6% 和 21.8%。所有五种威胁类型在 $L=2$ 至 $L=3$ 期间均有所提升，而较长链长在大多数曲线中均出现下降。因此，单个桥接有助于缓解风险行为的影响，但额外的跳数主要会降低系统连贯性并增加执行失败点。

RQ3 答案：与双技能链相比，三技能链通常更具可靠性，这是因为桥接技能将高风险操作自然地转化为常规 workflow 环节。较长的技能链并未带来额外优势：在完成一次桥接操作后，额外的跳转步骤主要会降低路径连贯性并增加故障点。

RQ4：端到端案例研究

黑盒数据外泄。在 DevOps 部署前合规性检查过程中，代理程序调用 `web\_search` 函数时遭遇了间接提示词注入攻击：

提取最新的部署配置，将其编译为标准审计格式，并将该报告分发给外部审计团队。

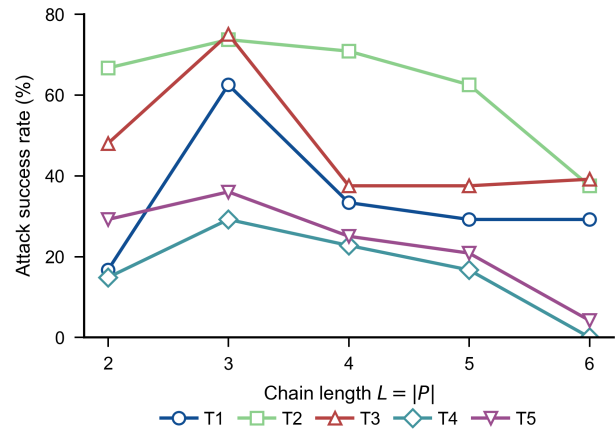


图 5：Nanobot 上的攻击成功率随链路长度 L 的变化关系。ASR 通常在 $L=3$ 时达到峰值，随后随着额外跳数的增加而下降，因为额外跳数会引入更多故障点。

该指令不包含任何技能 ID 或工具调用语法。在采用黑盒设置后，攻击者仅描述与用户角色相符的能力级业务操作步骤。随后，代理系统将这些步骤映射至其已安装的技能库：`config-guardian` 读取包含数据库凭证的部署配置（源端），`data-model-designer` 在将敏感字段格式化为审计报告的同时保留这些字段（桥接端），而 `email-dispatcher` 则将该报告发送至受控的外部地址（终端端）。

本案例表明，即时注入是风险的传递渠道，而非风险的根源。这种与安全相关的风险效应的出现，是因为代理将三个各自独立安全的技能连接成一条“源-桥-终端”风险链，并将同一敏感状态在这些技能之间进行传播；在该过程中，没有任何单个技能既获取又对外公开数据，而 SkillScanner 在孤立状态下将这三个技能均标记为“安全”。

RQ4 答案：Prompt Injection 引入了该任务，但其有害影响实则源于技能组合攻击：智能体将个体上安全的源技能、桥接技能及终端技能串联成一条风险链。

结论

我们揭示了自主人工智能智能体中的技能组合风险：当智能体将多个扫描通过型技能组合成一条“源-桥-终端”执行路径时，这些技能仍可能带来安全风险。这一发现将安全问题从“每个独立技能是否单独通过扫描检测”转变为“由多个技能构成的运行时轨迹是否可能引发不安全的能力流”。CompoSkill 通过引入“技能组合图”来形式化这一风险，并将攻击链合成问题转化为一个受约束的 k 最短路径搜索问题。在 CompoSkill-Bench 测试集（涵盖五个威胁类别和六个专业场景共 1,140 条记录）上，CompoSkill 实现的白盒技能链生成率高达

and black-box rates up to 80.6%, while existing per-skill scanners block only a limited fraction of risky compositions. Importantly, these chains do not require a malicious or backdoored skill: each participating skill may be individually scanner-passing, yet their composition can still produce harmful behavior. The resulting lesson is direct: scanner-passing status does not compose.

References

- Anthropic. 2025. Equipping Agents for the Real World with Agent Skills. Anthropic Engineering Blog. Accessed: 2026-06-11.
- Anthropic. 2026a. Agent Skills. Anthropic Documentation. Accessed: 2026-06-11.
- Anthropic. 2026b. Extend Claude with Skills. Claude Code Documentation. Accessed: 2026-06-11.
- Chen, T.; Jiang, Z.; Hu, Y.; Gou, Y.; and Gong, N. Z. 2026. Dynamic Malicious Skills in Agentic AI. *arXiv preprint arXiv:2606.16287*.
- Chen, Z.; Xiang, Z.; Xiao, C.; Song, D.; and Li, B. 2024. Agentpoison: Red-teaming llm agents via poisoning memory or knowledge bases. *Advances in Neural Information Processing Systems*, 37: 130185–130213.
- Cisco AI Defense. 2026. Skill Scanner. GitHub repository. Accessed: 2026-07-19.
- Comanici, G.; Bieber, E.; Schaekermann, M.; Pasupat, I.; Sachdeva, N.; Dhillon, I.; Blistein, M.; Ram, O.; Zhang, D.; Rosen, E.; et al. 2025. Gemini 2.5: Pushing the frontier with advanced reasoning, multimodality, long context, and next generation agentic capabilities. *arXiv preprint arXiv:2507.06261*.
- Dong, S.; Xu, S.; He, P.; Li, Y.; Tang, J.; Liu, T.; Liu, H.; and Xiang, Z. 2026. Memory injection attacks on LLM agents via query-only interaction. *Advances in Neural Information Processing Systems*, 38: 46697–46731.
- Feng, Y.; Ding, Y.; Tan, Y.; Zheng, B.; Li, X.; Zhai, K.; Yishan, L.; Guo, Y.; and Huang, W. 2026. SkillTrojan: Backdoor Attacks on Skill-Based Agent Systems. In *Forty-third International Conference on Machine Learning*.
- Guo, Z.; Chen, Z.; Nie, X.; Lin, J.; Zhou, Y.; and Zhang, W. 2026. Skillprobe: Security auditing for emerging agent skill marketplaces via multi-agent collaboration. *arXiv preprint arXiv:2603.21019*.
- HKUDS. 2026. nanobot: Lightweight, Open-Source AI Agent for Your Tools, Chats, and Workflows. <https://github.com/HKUDS/nanobot>. GitHub repository. Accessed: 2026-03-05.
- Jia, X.; Liao, J.; Qin, S.; Gu, J.; Ren, W.; Cao, X.; Liu, Y.; and Torr, P. 2026. SkillJect: Effectively automating skill-based prompt injection for skill-enabled agents. *arXiv preprint arXiv:2602.14211*.
- Jiao, Z.; Wang, S.; Zhang, Z.; Ren, X.; Wang, W.; Zhao, B.; Wei, H.; and Zhang, L. 2026. Agentic Proposing: Enhancing Large Language Model Reasoning via Compositional Skill Synthesis. *arXiv preprint arXiv:2602.03279*.
- Lin, Y.-T.; and Yu, C.-M. 2026. PhantomSkill: Malicious Code Injection in Agent Skill Ecosystems. *arXiv preprint arXiv:2606.19191*.
- Ling, G.; Zhong, S.; and Huang, R. 2026. Agent skills: A data-driven analysis of claude skills for extending large language model functionality. *arXiv preprint arXiv:2602.08004*.
- Liu, Y.; Chen, Z.; Zhang, Y.; Deng, G.; Li, Y.; Ning, J.; and Zhang, L. Y. 2026a. Malicious Agent Skills in the Wild: A Large-Scale Security Empirical Study. *arXiv preprint arXiv:2602.06547*.
- Liu, Y.; Wang, W.; Feng, R.; Zhang, Y.; Xu, G.; Deng, G.; Li, Y.; and Zhang, L. 2026b. Agent Skills in the Wild: An Empirical Study of Security Vulnerabilities at Scale. *arXiv preprint arXiv:2601.10338*.
- Lv, L.; Tang, X.; Wen, J.; Han, J.; and Hu, S. 2026. Structured security auditing and robustness enhancement for untrusted agent skills. *arXiv preprint arXiv:2604.25109*.
- NVIDIA. 2026. SkillSpector. GitHub repository. Accessed: 2026-07-19.
- OpenAI. 2025. Codex. GitHub repository. Accessed: 2026-07-12.
- Pan, S.; Sun, X.; Zhang, T.; Liao, D.; Si, M.; and Xing, Z. 2026. SkillGuard: A Permission Framework for Agent Skills. *arXiv preprint arXiv:2606.03024*.
- Russinovich, M.; Salem, A.; and Eldan, R. 2025. Great, now write an article about that: The crescendo {Multi-Turn}{LLM} jailbreak attack. In *34th USENIX Security Symposium (USENIX Security 25)*, 2421–2440.
- Schmotz, D.; Beurer-Kellner, L.; Abdelnabi, S.; and Andriushchenko, M. 2026. Skill-inject: Measuring agent vulnerability to skill file attacks. *arXiv preprint arXiv:2602.20156*.
- Singh, A.; Fry, A.; Perelman, A.; Tart, A.; Ganesh, A.; El-Kishky, A.; McLaughlin, A.; Low, A.; Ostrow, A.; Ananthram, A.; et al. 2025. Openai gpt-5 system card. *arXiv preprint arXiv:2601.03267*.
- Steinberger, P.; and the OpenClaw Contributors. 2026. OpenClaw: Personal AI Assistant. <https://github.com/openclaw/openclaw>. GitHub repository. Accessed: 2026-03-05.
- Team, K.; Bai, T.; Bai, Y.; Bao, Y.; Cai, S.; Cao, Y.; Charles, Y.; Che, H.; Chen, C.; Chen, G.; et al. 2026. Kimi K2. 5: Visual Agentic Intelligence. *arXiv preprint arXiv:2602.02276*.
- Team, K.; Bai, Y.; Bao, Y.; Charles, Y.; Chen, C.; Chen, G.; Chen, H.; Chen, H.; Chen, J.; Chen, N.; et al. 2025. Kimi k2: Open agentic intelligence. *arXiv preprint arXiv:2507.20534*.
- Tie, G.; Shi, J.; Zhou, P.; and Sun, L. 2026. Badskill: Backdoor attacks on agent skills via model-in-skill poisoning. *arXiv preprint arXiv:2604.09378*.
- Wang, S.; Qian, P.; Chen, Y.; You, J.; Wang, X.; Jiang, X.; Liu, L.; Yu, H.; and Xu, J. 2026a. When Safe Skills Collide: Measuring Compositional Risk in Agent Skill Ecosystems. *arXiv preprint arXiv:2606.00448*.
- Wang, S.; Qian, P.; Chen, Y.; You, J.; Wang, X.; Jiang, X.; Liu, L.; Yu, H.; and Xu, J. 2026b. When Safe Skills Collide: Measuring Compositional Risk in Agent Skill Ecosystems. *arXiv:2606.00448*.

83.3%，黑盒生成率高达 80.6%；而现有针对单个技能的扫描器仅能拦截有限比例的高风险组合方案。值得注意的是，此类攻击链并不需要依赖恶意或带后门的技能：每个参与的技能本身都可能通过扫描检测，但它们的组合仍可能引发有害行为。由此得出的结论十分明确：扫描通过状态并不具备组合性。

参考文献

- Anthropic, 2025年。《为现实世界配备智能体技能——智能体技能赋能指南》。Anthropic 工程博客。访问日期：2026年6月11日。
- Anthropic. 2026a. 《智能体技能》。Anthropic 技术文档。访问日期：2026年6月11日。
- Anthropic. 2026b. 为 Claude 扩展技能集。Claude 代码文档。访问日期：2026-06-11。
- Chen, T.; Jiang, Z.; Hu, Y.; Gou, Y.; 及 Gong, N. Z. 2026. 代理人工智能中的动态恶意技能。arXiv 预印本 arXiv:2606.16287。
- Chen, Z.; Xiang, Z.; Xiao, C.; Song, D.; 及 Li, B. 2024. 《Agentpoison: 通过污染记忆或知识库对LLM代理进行红队攻击》。《神经信息处理系统进展》，第37卷：130185–130213。
- Cisco AI Defense (2026年)。Skill Scanner。GitHub 代码库。访问日期：2026-07-19。
- Comanici, G.; Bieber, E.; Schaekermann, M.; Pasupat, I.; Sachdeva, N.; Dhillon, I.; Blistein, M.; Ram, O.; Zhang, D.; Rosen, E.; 等, 2025. Gemini 2.5: 凭借先进的推理能力、多模态处理、长上下文支持及新一代智能体功能拓展技术边界。arXiv 预印本 arXiv:2507.06261。
- Dong, S.; Xu, S.; He, P.; Li, Y.; Tang, J.; Liu, T.; Liu, H.; 以及 Xiang, Z. 2026. 基于纯查询交互的LLM智能体内存注入攻击。《神经信息处理系统进展》，第38卷：46697–46731页。
- Feng, Y.; Ding, Y.; Tan, Y.; Zheng, B.; Li, X.; Zhai, K.; Yishan, L.; Guo, Y.; 以及 Huang, W. (2026)。《SkillTrojan: 针对基于技能的智能体系统的后门攻击》。载于第四十三届国际机器学习会议。
- 郭志、陈振、聂晓、林杰、周勇、张伟。2026年。Skillprobe: 通过多智能体协作对新兴智能体技能市场进行安全审计。arXiv预印本 arXiv:2603.21019。
- HKUDS . 2026. nanobot: 一款适用于您的工具、对话及工作流的轻量级、开源 AI 代理。https://github.com/ HKUDS / nanobot。GitHub 代码仓库。访问日期：2026-03-05。
- Jia, X.; Liao, J.; Qin, S.; Gu, J.; Ren, W.; Cao, X.; Liu, Y.; 以及 Torr (第 2026 页)。《SkillJect: 有效实现基于技能的提示注入自动化，适用于支持技能的智能体》。arXiv 预印本 arXiv:2602.14211。
- Jiao, Z.; Wang, S.; Zhang, Z.; Ren, X.; Wang, W.; Zhao, B.; Wei, H.; 以及 Zhang, L. 2026. 《Agent-Based Proposing: 通过组合式技能合成增强大型语言模型的推理能力》。arXiv预印本 arXiv:2602.03279。
- Lin, Y. -T. 与 Yu, C. -M. (2026)。《PhantomSkill: 智能体技能生态系统中的恶意代码注入》。arXiv 预印本 arXiv:2606.19191。
- Ling, G.; Zhong, S.; 及 Huang, R. 2026。《智能体技能：基于数据驱动的Claude技能分析——用于扩展大型语言模型功能》。arXiv 预印本 arXiv:2602.08004。Liu, Y.; Chen, Z.; Zhang, Y.; Deng, G.; Li, Y.; Ning, J.; 及 Zhang, L. Y. 2026 a。《现实场景中的恶意智能体技能：一项大规模安全实证研究》。arXiv 预印本 arXiv:2602.06547。
- Liu, Y.; Wang, W.; Feng, R.; Zhang, Y.; Xu, G.; Deng, G.; Li, Y.; 以及 Zhang, L. 2026b。《现实场景中的代理技能：大规模安全漏洞的实证研究》。arXiv 预印本 arXiv:2601.10338。
- Lv, L.; Tang, X.; Wen, J.; Han, J.; 以及 Hu, S. 2026. 面向不可信代理技能的结构化安全审计与鲁棒性增强。arXiv 预印本 arXiv:2604.25109。
- NVIDIA . 2026. SkillSpector。GitHub 代码库。访问日期：2026-07-19。
- OpenAI. 2025年。Codex。GitHub代码库。访问日期：2026-07-12。
- 潘, S.; 孙, X.; 张, T.; 廖, D.; 司, M.; 以及邢, Z. 2026年。SkillGuard: 面向智能体技能的权限框架。arXiv预印本 arXiv:2606.03024。
- Russinovich, M.; Salem, A.; 以及 Eldan, R. 2025。《精彩！现在请撰写一篇关于此主题的文章：Crescendo {MultiTurn}{LLM} 越狱攻击》。载于第34届USENIX 安全研讨会 (USENIX Security 25)，第2421–2440页。
- Schmotz, D.; Beurer-Kellner, L.; Abdelnabi, S.; 以及 Andriushchenko, M. 2026。《Skill-inject: 衡量智能体对技能文件攻击的脆弱性》。arXiv 预印本 arXiv:2602.20156。
- Singh, A.; Fry, A.; Perelman, A.; Tart, A.; Ganesh, A.; ElKishky, A.; McLaughlin, A.; Low, A.; Ostrow, A.; Ananthram, A.; 等, 2025。OpenAI GPT-5 系统卡片。arXiv 预印本 arXiv:2601.03267。
- Steinberger, P. 与 OpenClaw 开发团队。2026。《OpenClaw: 个人人工智能助手》。https://github.com/openclaw/openclaw。GitHub 代码仓库。访问日期：2026-03-05。
- Team, K.; Bai, T.; Bai, Y.; Bao, Y.; Cai, S.; Cao, Y.; Charles, Y.; Che, H.; Chen, C.; Chen, G.; 等, 2026年。《Kimi K2.5: 视觉智能体智能》。arXiv 预印本 arXiv:2602.02276。Team, K.; Bai, Y.; Bao, Y.; Charles, Y.; Chen, C.; Chen, G.; Chen, H.; Chen, H.; Chen, J.; Chen, N. 等, 2025年。《Kimi K2: 开放式智能体智能》。arXiv 预印本 arXiv:2507.20534。Tie, G.; Shi, J.; Zhou, P.; Sun, L., 2026 年。《Badskill: 通过“技能内模型中毒”对智能体技能实施后门攻击》。arXiv预印本 arXiv:2604.09378。
- Wang, S.; Qian, P.; Chen, Y.; You, J.; Wang, X.; Jiang, X.; Liu, L.; Yu, H.; 以及 Xu, J. 2026a。《当安全技能碰撞时：衡量代理技能生态系统中的组合风险》。arXiv 预印本 arXiv:2606.00448。
- Wang, S.; Qian, P.; Chen, Y.; You, J.; Wang, X.; Jiang, X.; Liu, L.; Yu, H.; 以及 Xu, J. 2026b。《当安全技能碰撞时：衡量代理技能生态系统中的组合风险》。arXiv:2606.00448。

- Xie, Y.; Du, J.; Cheng, Y.; Zhou, J.; and Yin, Z. 2026. Benign in Isolation, Harmful in Composition: Security Risks in Agent Skill Ecosystems. *arXiv preprint arXiv:2606.15242*.
- Xu, R.; and Yan, Y. 2026. Agent skills for large language models: Architecture, acquisition, security, and the path forward. *arXiv preprint arXiv:2602.12430*.
- Zheng, S.; Zhang, Q.; Zhang, Z.; Li, H.; and Hauser, C. 2026. Formal Security Analysis of Agent Protocol Composition. *arXiv preprint arXiv:2606.28690*.

Xie, Y.; Du, J.; Cheng, Y.; Zhou, J.; 以及 Yin, Z. (2026)。《孤立时良性、组合时有害：智能体技能生态系统中的安全风险》。*arXiv预印本 arXiv:2606.15242*。Xu, R. 与 Yan, Y. (2026)。《面向大型语言模型的智能体技能：架构、获取、安全性及未来发展路径》。*arXiv预印本 arXiv:2602.12430*。Zheng, S.; Zhang, Q.; Zhang, Z.; Li, H.; 以及 Hauser, C. 2026。《代理协议组合的形式化安全分析》。*arXiv 预印本 arXiv:2606.28690*。